Contents

Gestión de Riesgos 1
Matriz de riesgos 1
Descripción y plan de acción por riesgo 4
R-01 — No contar con acceso real a la API de Contífico (riesgo dominante) 4
R-02 — Inconsistencia entre saldo, facturación e inventario 4
R-03 — Baja experiencia del equipo creando APIs seguras 4
R-04 — Disponibilidad limitada de los integrantes 4
R-05 — Falta de validación operativa con Barú 4
R-06 — Limitaciones del ambiente de pruebas de pagos 4
R-07 — Fallas o incompatibilidades en herramientas de desarrollo 5
R-08 — Cambios en el flujo de saldo y comprobantes 5
R-09 — Requisitos de seguridad incompletos 5
R-10 — Subestimación del esfuerzo de integración y pruebas 5
R-11 — Alpwin (sistema de Caramel Coffee) no tiene API pública documentada 5
R-17 — Cartilla de fidelidad con reglas sin definir 5
R-15 — El código de retiro numérico corto es adivinable 6
R-16 — Costo operativo de sostener varios ERP heterogéneos a la vez 6
Riesgos identificados en la revisión del flujo funcional 6
R-14 — Doble redención del código de retiro 7
Riesgos derivados del modelo de saldo por establecimiento 7
R-21 — Saldo fragmentado entre establecimientos 7
R-22 — Un local sin cuenta de comercio en la pasarela 8
R-23 — Saldo huérfano que Aliflow no puede devolver 8
R-20 — El cupo reservado depende de mantenimiento manual del proveedor 8

Gestión de Riesgos

Proyecto: Aliflow — sistema web para pedir y pagar el almuerzo dentro del campus de la UEES

Clasificación de tipos de riesgo: Tecnológico, Humano, Organizacional, Herramientas, Requerimientos, Estimación.

Escalas usadas: **Probabilidad** (Muy Baja / Baja / Media / Alta / Muy Alta), **Impacto** (Mínimo / Leve / Moderado / Grave / Catastrófico), **Estrategia** (Evitar / Transferir / Mitigar / Aceptar).

Matriz de riesgos

Tabla 1: Matriz de riesgos del proyecto

ID	Nombre	Tipo	Probabilidad	Impacto	Estrategia
R-01	No contar con acceso real a la API de Contífico — **el ERP del local piloto**	Tecnológico	Media	**Catastrófico**	Evitar

ID	Nombre	Tipo	Probabilidad	Impacto	Estrategia
R-02	Inconsistencia entre saldo, facturación e inventario	Tecnológico	Media	Grave	Transferir
R-03	Baja experiencia del equipo creando APIs seguras	Humano	Media	Moderado	Mitigar
R-04	Disponibilidad limitada de los integrantes	Humano	Media	Leve	Mitigar
R-05	Falta de validación operativa con Barú	Organizacional	Media	Grave	Transferir
R-06	Limitaciones del ambiente de pruebas de pagos	Herramientas	Media	Moderado	Mitigar
R-07	Fallas o incompatibilidades en herramientas de desarrollo	Herramientas	Baja	Leve	Aceptar
R-08	Cambios en el flujo de saldo y comprobantes	Requerimientos	Alta	Grave	Evitar
R-09	Requisitos de seguridad incompletos	Requerimientos	Media	Moderado	Mitigar
R-10	Subestimación del esfuerzo de integración y pruebas	Estimación	Media	Moderado	Mitigar
R-11	Alpwin (sistema de **Caramel Coffee**, no de Barú) no tiene API pública documentada	Tecnológico	Alta	**Moderado**	Mitigar
R-15	Código de retiro numérico de 6 dígitos: adivinable por fuerza bruta	Tecnológico	Baja	Moderado	Mitigar
R-16	Costo operativo de sostener N ERP heterogéneos a la vez (credenciales, formatos de error, soporte, pruebas)	Estimación	Alta	Grave	Mitigar

ID	Nombre	Tipo	Probabilidad	Impacto	Estrategia
R-17	Alcance del programa de fidelidad: riesgo de que el local regale premios por ventas que no ocurrieron	Requerimientos	Baja	Moderado	Mitigar
R-20	El inventario reservado depende de que el proveedor lo mantenga al día manualmente: si no repone el cupo, Aliflow aparece agotado aunque el local tenga comida	Organizacional	**Alta**	Moderado	Mitigar
R-21	**Saldo fragmentado entre establecimientos** — el estudiante puede tener dinero repartido en varios locales y no poder comprar en ninguno	Requerimientos	**Alta**	Moderado	Mitigar
R-22	**Un local no puede o no quiere abrir cuenta de comercio** en la pasarela elegida — sin ella no puede recibir recargas ni vender por Aliflow	Organizacional	Media	**Grave**	Mitigar
R-23	**Saldo huérfano** — el estudiante se gradúa o el local sale de la plataforma y queda saldo sin usar que Aliflow no puede devolver porque nunca tuvo el dinero	Organizacional	Media	Moderado	Transferir

Descripción y plan de acción por riesgo

R-01 — No contar con acceso real a la API de Contífico (riesgo dominante)
Descripción: El establecimiento piloto usa Contífico. Su API REST existe y está documentada, pero la API Key la entrega el soporte de Contífico únicamente al titular de la cuenta — es decir, **depende de que el establecimiento la solicite y la comparta**. Si eso no ocurre, no hay adaptador de producción posible y el piloto se queda en el demo con Odoo. Es el único riesgo del proyecto cuyo impacto es catastrófico y que **no depende del equipo de desarrollo**. **Acción:** (1) Pedir formalmente las credenciales por escrito ya, no cuando el adaptador esté listo — el tiempo de respuesta de un tercero es la variable que no controlamos. (2) Escribir el `ContificoAdapter` contra la documentación y probarlo con un mock local mientras tanto, para que el día que lleguen las credenciales solo haya que conectarlo. (3) No comprometer fecha de piloto con el cliente hasta tenerlas.

R-02 — Inconsistencia entre saldo, facturación e inventario
Descripción: Una compra podría descontar saldo en Aliflow, pero fallar al registrar la factura o el descuento de inventario en el sistema externo. **Acción:** Delegar la emisión contable final al ERP/proveedor autorizado y registrar en Aliflow estados de sincronización. Implementar bitácora, reintentos, estados PENDIENTE/FACTURADO/ERROR y procedimiento de conciliación con el responsable de Barú. (Ver patrón outbox en `../../Hallazgos-Ingenieria-API-Generica.md` sección 3.4 — ya validado técnicamente en el demo con Odoo.)

R-03 — Baja experiencia del equipo creando APIs seguras
Descripción: El equipo ha consumido APIs, pero tiene poca experiencia construyendo endpoints propios con autenticación, roles, validaciones y manejo seguro de datos. **Acción:** Dividir responsabilidades, revisar buenas prácticas OWASP, usar un framework documentado, hacer revisiones de código entre integrantes y priorizar endpoints críticos: autenticación, wallet, órdenes y validación de códigos.

R-04 — Disponibilidad limitada de los integrantes
Descripción: Las cargas académicas y horarios del grupo pueden retrasar el desarrollo de módulos clave como pagos, wallet, panel de Operador e integración externa. **Acción:** Planificar sprints cortos, asignar responsables por módulo, usar tablero Kanban, definir fechas de entrega internas y mantener reuniones breves de seguimiento dos veces por semana.

R-05 — Falta de validación operativa con Barú
Descripción: El flujo real de preparación, retiro, comprobantes y control de almuerzos podría diferir de lo asumido por el equipo durante el diseño. **Acción:** Solicitar validación del flujo a un representante de Barú/UEES y dejar documentadas las reglas del proceso. Las decisiones operativas finales deben ser aprobadas por el dueño del proceso antes de cerrar el alcance.

R-06 — Limitaciones del ambiente de pruebas de pagos
Descripción: La pasarela de pagos seleccionada puede no disponer de sandbox completo, webhooks o documentación suficiente para simular recargas de saldo. **Acción:** Usar un modo de pago

simulado para el prototipo, registrar pagos con estados APROBADO/PENDIENTE/RECHAZADO y diseñar la capa de pagos para reemplazar el simulador por una pasarela real cuando exista acceso.

R-07 — Fallas o incompatibilidades en herramientas de desarrollo
Descripción: Problemas con hosting, base de datos, librerías, repositorio o entorno local pueden afectar la integración y las pruebas del proyecto. **Acción:** Aceptar el riesgo por su impacto bajo, manteniendo respaldos del repositorio, archivo README de instalación, variables de entorno documentadas y una alternativa local con base de datos de desarrollo.

R-08 — Cambios en el flujo de saldo y comprobantes
Descripción: Podrían cambiar las reglas sobre la recarga de saldo, comprobante no contable y emisión de comprobante válido únicamente al consumir el almuerzo. **Acción:** Congelar el alcance funcional aprobado: recarga con comprobante interno y compra con comprobante válido en el ERP. Cualquier cambio pasa por control de cambios y reestimación.

R-09 — Requisitos de seguridad incompletos
Descripción: No definir correctamente roles, permisos, protección de tokens, validación de códigos de retiro y auditoría puede abrir fallas de seguridad. **Acción:** Definir los **4 roles** del sistema (Estudiante, Operador, Proveedor y Super-Admin de Aliflow); usar autenticación con tokens, contraseñas cifradas, validaciones en backend, expiración de códigos de retiro y registro de auditoría para compras y redenciones. **Ya modelado:** clase `RegistroAuditoria` agregada al diagrama de clases (`../../uml/diagrama-clases.puml`, paquete "Órdenes"), registrando quién ejecuta las operaciones que cambian dinero o estado de una orden.

R-10 — Subestimación del esfuerzo de integración y pruebas
Descripción: El equipo puede subestimar el trabajo necesario para probar wallet, órdenes, inventario simulado, facturación, errores y seguridad. **Acción:** Construir primero un MVP con registro, saldo, compra y código de retiro; luego agregar Mock ERP/adaptador real, reportes y validaciones. Reservar tiempo específico para pruebas de integración y corrección de errores.

R-11 — Alpwin (sistema de Caramel Coffee) no tiene API pública documentada
Descripción: Alpwin, el ERP del segundo establecimiento, no tiene documentación pública de API. Degrada el alcance de la plataforma —un local que no se puede integrar en tiempo real — sin bloquear el piloto, que usa un ERP con API REST documentada. **Acción:** Contactar a Syscompsa para descartar o confirmar una vía de integración no pública, **después** de tener el `ContificoAdapter` andando. Si no hay vía, construir el adaptador por archivos/BD puente y aceptar sincronización por lotes para ese local. La conversación de "migrar de sistema" corresponde plantearla a ese local específico, no al proyecto entero.

R-17 — Cartilla de fidelidad con reglas sin definir
Descripción: El programa de fidelidad presenta dos problemas distintos: 1. **De alcance:** un requisito nuevo entrando después de que el diseño estaba cerrado. Si además llega con reglas que cambian (puntos en vez de sellos, premios escalonados, campañas por temporada), el módulo se convierte en un pozo sin fondo dentro de un proyecto de taller con fecha de entrega. 2. **De**

negocio: según cómo se defina "una compra", el local puede terminar regalando premios por ventas que no ocurrieron. Si el sello se acredita al comprar, un estudiante llena la cartilla sin retirar nunca el almuerzo. Si no hay tope diario, la llena en un día comprando el ítem más barato varias veces.

Acción: (1) Modelar los dos datos faltantes como **configuración** (`sellosRequeridos`, `descripcionPremio`) y no como constantes, para que definirlos sea un valor en base de datos y no un cambio de diseño — **ya aplicado**. (2) Acreditar el sello en `marcarEntregado`, no en `confirmarCompra`, y hacer `Sello → Orden` único — **ya aplicado**, cierra el agujero de llenar la cartilla sin retirar. (3) Tope `maxSellosPorDia = 1` por defecto — **ya aplicado**. (4) **Congelar el alcance del módulo a una cartilla simple** (N sellos ⟶ 1 premio, por local): cualquier variante más rica (puntos, niveles, campañas) va a control de cambios con reestimación, igual que R-08.

R-15 — El código de retiro numérico corto es adivinable

Descripción: El código de retiro es **numérico de 6 dígitos** porque el estudiante lo dicta de viva voz y el Operador lo digita, lo que descarta un identificador largo. Eso tiene un costo de seguridad: el espacio de búsqueda es de 10^6 combinaciones, y en la práctica es mucho menor, porque solo son válidos los pocos códigos vigentes de ese local en ese momento. Un atacante que pruebe códigos al azar en el panel del Operador podría acertar el almuerzo de otro estudiante. **Acción:** (1) Limitar los intentos fallidos de validación por sesión de Operador y por ventana de tiempo. (2) Expiración corta del código (horario de almuerzo, no todo el día), que reduce cuántos están vigentes a la vez. (3) Que el panel muestre el nombre del estudiante antes de confirmar la entrega — el Operador lo tiene enfrente, así que un código acertado por azar se cae en la verificación visual. (4) Registrar cada validación fallida en el registro de auditoría. **Riesgo residual aceptable**: la mitigación (3) es fuerte porque la entrega es presencial.

R-16 — Costo operativo de sostener varios ERP heterogéneos a la vez

Descripción: Que cada establecimiento use su propio ERP convierte a Aliflow en una plataforma multi-tenant real. El patrón Adapter resuelve el problema de **diseño**, pero no el de **operación**: cada local nuevo trae su propio juego de credenciales que gestionar y rotar, su propio formato de errores que interpretar, su propio interlocutor de soporte cuando algo falla, y su propio entorno de pruebas (que puede no existir). Es exactamente el tipo de trabajo que R-10 advierte que se subestima. **Acción:** (1) Tratar el alta de cada local como un mini-proyecto con su propio checklist (credenciales, mapeo de productos al modelo canónico, prueba de humo bidireccional), no como un cambio de configuración. (2) Que el panel de estado de sincronización (UC10) sea por local y le sirva **al equipo de Aliflow** para monitorear, no solo al proveedor. (3) Para el alcance del taller, limitar el número de locales integrados a los dos confirmados (Barú y Caramel Coffee) y dejar los demás como demostración de extensibilidad, no como entregable.

Riesgos identificados en la revisión del flujo funcional

Detectados durante la revisión del flujo funcional del sistema:

Tabla 2: Riesgos identificados en la revisión del flujo funcional

ID	Nombre	Tipo	Probabilidad	Impacto	Estrategia
R-12	Operador sin modo offline en v1 (decisión de negocio ya confirmada) — un fallo de conectividad en el punto de entrega bloquea toda entrega de almuerzos	Tecnológico	Media	Grave	Aceptar (con plan de contingencia manual documentado)
R-13	Órdenes "Comprado" sin estado de expiración/no-show — no hay regla definida para una orden nunca retirada	Requerimientos	Media	Moderado	Mitigar (definir el estado y su regla de negocio antes de construir el diagrama de estados)
R-14	Doble redención del código de retiro — dos Operadores podrían validar el mismo código casi simultáneamente	Tecnológico	Baja	Grave	Mitigar

R-14 — Doble redención del código de retiro

Descripción: si dos Operadores (posiblemente en distintos puntos de entrega del mismo local) intentan validar el mismo `CodigoRetiro` casi al mismo tiempo, sin un mecanismo atómico ambos podrían marcar la entrega como exitosa, resultando en dos entregas físicas de un mismo almuerzo. **Acción:** ya resuelto a nivel de diseño — la invalidación del código se modela como una actualización atómica y condicional (`UPDATE... WHERE usado = false`), igual que el mecanismo de bloqueo optimista usado para el stock (`Plato.version`). Si la actualización afecta 0 filas, se informa error en vez de completar una segunda entrega. Ver `../../uml/secuencia-retiro-entrega.puml`.

Riesgos derivados del modelo de saldo por establecimiento

R-21 — Saldo fragmentado entre establecimientos

Descripción: al ser el saldo por establecimiento, un estudiante con $6 en un local y $4 en otro **no puede comprar un almuerzo de $7 en ninguno de los dos**, pese a tener $10 en la plataforma. La fragmentación es elegida por el estudiante, no automática, lo que la hace tolerable pero no la elimina. Además la fricción crece con cada local: comer en dos locales significa administrar dos saldos y hacer dos recargas. **Por qué es Alta:** no es un caso raro. Basta con recargar un monto que no sea múltiplo del precio del almuerzo para ir dejando restos en cada local. **Acción:** (1) Que la interfaz muestre siempre el saldo del establecimiento activo y advierta al recargar que ese dinero solo sirve ahí (RF-08 criterio 6, RF-15). (2) Sugerir montos de recarga alineados con el precio de

los platos de ese local, en vez de montos redondos genéricos. (3) Al fallar una compra por saldo insuficiente, ofrecer recargar en ese mismo local sin salir del flujo (RF-12 criterio 3). (4) Medir cuántas compras se pierden por saldo insuficiente teniendo saldo en otro local, para dimensionar el impacto real.

R-22 — Un local sin cuenta de comercio en la pasarela

Descripción: que el dinero vaya directo a la cuenta de cada proveedor implica que **cada local necesita su propia cuenta de comercio** en la pasarela que se elija. Si un local no puede abrirla (requisitos bancarios, RUC, volumen mínimo) o no quiere asumir su comisión, no puede recibir recargas — y por lo tanto no puede vender por Aliflow, aunque su ERP esté integrado y su menú publicado. **Por qué es Grave:** convierte el alta de un local en una gestión financiera, no solo técnica. Es un requisito nuevo de admisión a la plataforma que antes no existía. **Acción:** (1) Verificar con los dos locales confirmados que pueden abrir cuenta **antes** de seleccionar pasarela (RNF-E-11b). (2) Incorporar "cuenta de comercio activa" a la lista de verificación de alta de local (RNF-O-06). (3) Si los locales no coinciden en una misma pasarela, evaluar soportar más de una — con el costo de integración que eso implica, análogo a R-16 pero en pagos.

R-23 — Saldo huérfano que Aliflow no puede devolver

Descripción: un estudiante se gradúa, o un local sale de la plataforma, y queda saldo sin consumir. **Aliflow no puede devolverlo porque nunca tuvo el dinero** (RN-14): es una obligación del establecimiento con el estudiante. Pero el reclamo va a llegar a Aliflow igual, porque la aplicación es la cara visible. **Acción:** (1) **Transferir el riesgo por contrato:** que el acuerdo comercial con cada local establezca explícitamente qué pasa con el saldo no consumido y quién responde. (2) Que la aplicación lo comunique al estudiante en la recarga (RNF-E-05b). (3) Avisar al estudiante con saldo remanente antes de que un local se desactive. (4) Definir un plazo y una política de saldo inactivo, acordados con el local — es la misma pregunta abierta que el reembolso de órdenes expiradas y conviene resolverlas juntas.

R-20 — El cupo reservado depende de mantenimiento manual del proveedor

Descripción: el inventario reservado elimina la sobreventa, pero introduce una dependencia operativa nueva: si el proveedor no repone el cupo, Aliflow muestra "agotado" mientras el local sigue teniendo comida. El fallo es silencioso — nadie se queja porque nadie ve lo que no puede comprar — y se traduce en venta perdida. **Acción:** (1) Alertar al proveedor en su panel cuando el cupo baje de un umbral. (2) Registrar los intentos de compra rechazados por cupo agotado y mostrarlos como métrica, para que la venta perdida sea **visible**. (3) Evaluar para v2 una reposición automática desde el stock del ERP cuando la integración esté disponible.
